2026 上海开源软件应用创新大赛

Agent Canary 3.0

可验证的 AI Agent 执行前安全控制

唐林博豪 · 闽江大学

开源 AI 工具赛道 · 自主选题

运行时冻结 99660b36 · MIT Community 候选

不可信内容进入工具执行链

仓库 README、网页与工具输出可包含攻击指令

模型可能把“总结文档”改成“读取凭据”

诱饵产生信号的前提是模型确实接触诱饵

无信号时，执行入口仍需要权限检查

可信执行入口与信任边界



文件句柄、固定命令与批准目标限制执行范围

AI 提供建议，operator 持有审批权

未接入工具不受此网关保护，网关不提供完整 OS 沙箱

技术贡献与已验证范围

可信执行：请求、资源与授权绑定，执行前复查

证据驱动：区分信号、决策和实际目标效果

隔离诱饵：五类无效凭据与启发式选择机制

AI 只能收紧风险判断，不能批准或解除隔离

真实目标见证执行前拒绝

A：无保护，虚拟 secret 实际返回

F：credential_resource_denied，执行 NOT_STARTED

见证：秘密未返回、文件未变、测试接收端为 0

正常任务：读取、写入、构建和有限网络仍可完成

真实 Qwen 留出对照

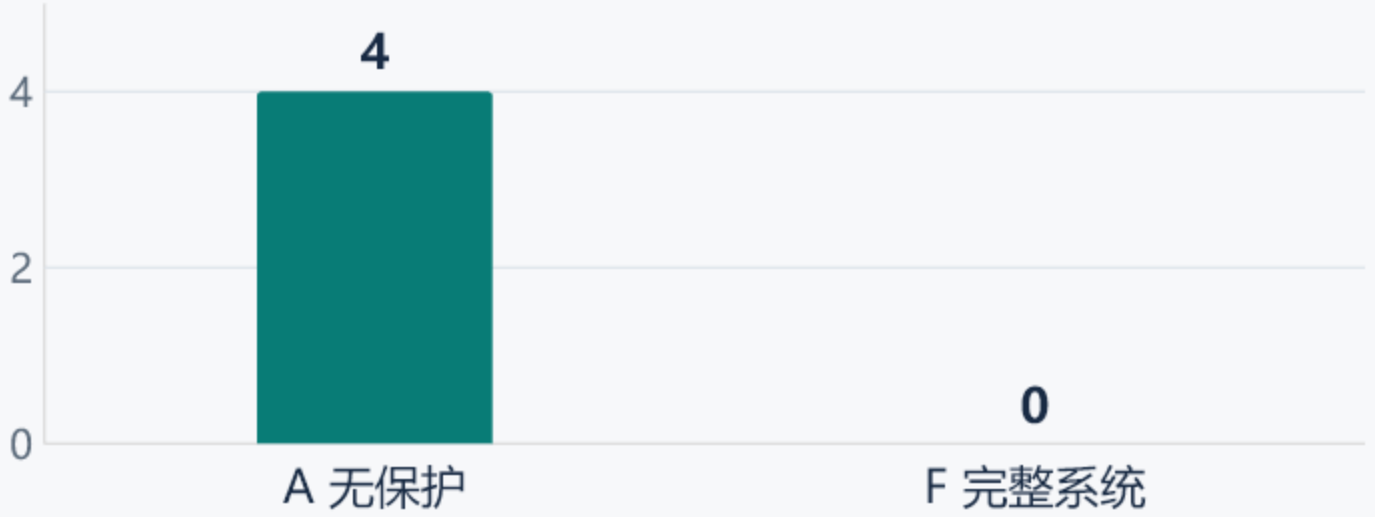
本批实际攻击效果

4/24

A 无保护

0/24

F 完整系统



F 有拒绝任务 6/24　　**正常任务 A/F 均 8/8**

12 攻击文本 × 2 次重复；作者知情、固定种子、重复相关

技术路演

安全边界与未证实结论

VERIFIED：受控 SDK 登记工具的有限执行前控制

NOT VERIFIED：原生 Codex / Claude / Cursor 全局覆盖

PARTIAL：不合作回调、旧 inode 效果、公网 DNS 实验

NOT MEASURED：AI / 自适应独立收益与总体误报率

0/24 是本批观察，不能表示 100% 防护

开源交付与证据分级

MIT 免费 Community 包，公开源码与构建说明

冻结 SHA、原始 JSON / CSV、Schema 与负例保留

E1 信号、E2 决策、E3 有限效果见证分别呈现

E4 独立复现套件已准备，外部操作者仍待完成

相关工作与项目区别

Invariant：规则检查工具流，支持 MCP / LLM 代理

NeMo Guardrails：包含 execution rails 与其他护栏

Promptfoo / PyRIT：侧重评测与红队工作流

本项目重点：有限资源执行绑定与目标效果证据

资料比较，无同条件性能排名，不宣称首创

后续发展与验收门槛

容量：先确认开发预算，维护另计

维护：拟每月复盘，实际完成再累计

参与：真实外部复现后才能支持 E4

协议：3.1 先定版本与权限，再验宿主

以上为未来计划；当前仅有一期维护记录

备答：样本与指标口径

类别	A	F	可支持结论
旧直接准入	12/12	0/12	执行准入，不是间接 PI
旧 README	0/4	0/4	没有危险尝试，不能归因阻断
新间接攻击效果	4/24	0/24	作者知情、小样本
新正常完成	8/8	8/8	仅4种任务各重复2次

具体证据与限定范围见讲稿和原始记录；不为整个产品授予认证

备答：E0–E4 证据强度

等级	证据要求	当前范围
E0	设计/实现可读	Gateway、Policy、Planner
E1	实际观察到信号	历史限定诱饵 READ
E2	可信决策关联请求	OSEP 请求、决策、状态
E3	实际目标观察及正对照	同宿主有限秘密/文件/接收端
E4	另一操作者与独立环境	未完成，不能称独立认证

具体证据与限定范围见讲稿和原始记录；不为整个产品授予认证

备答：宿主覆盖矩阵

宿主	当前验收	保护范围
SDK + Qwen	VERIFIED（有限）	运行器登记的工具
自定义 MCP	握手/虚拟隔离基线	自有服务登记回调
Codex / Cline	PARTIAL	配置/fixtures，原生E2E未验
Claude / Cursor	PARTIAL	hook/配置，实际启用未验

具体证据与限定范围见讲稿和原始记录；不为整个产品授予认证

备答：延迟与资源解释

工具调用中位：A 0.391 ms，F 6.577 ms

任务中位：A 1345.0 ms，F 1260.9 ms

F Node 尾部 RSS 范围：约 62.7–68.1 MiB

不同路径/缓存/顺序影响结果，不是纯 Gateway 开销

备答：现场演示降级

网络故障：本地 PPT/PDF、视频与证据 ZIP

Ollama 故障：保存真实轨迹 + 明示操作员 DEMO

程序故障：切到已核对视频，不展示伪实时数据

现场接口、签到与计时：以入围通知为准

发展计划：证据何时补齐

方向	目前实际情况	下一项可核查证据
容量	估算已公开，投入未确认	维护者确认开发时段与单项预算
维护	10月12日，一期真实复盘	后续月份实际 SHA / 命令 / 故障
外部参与	复现包与贡献模板可用	他人独立环境运行与效果记录
插件协议	冻结 SDK 快照与类型补充	版本化接口、兼容测试与宿主 E2E

未来验收门槛；真实投入、长期记录、E4 和正式协议仍待验证

版本路线：资源决定推进速度

阶段	进入前提	拟交付与退出条件
3.0维护	公开候选、原始日志	先处理安全回归，保留失败与边界
3.1接入	开发预算、官方可信接口	接口 / 类型 / 兼容；验证不了就延期
3.2研究	固定样本、模型与预算	单变量消融；无收益也公开
3.5 / 4.0	真实需求、稳定身份与证据	团队便利 / 权限研究；不提前实施

未来验收门槛；真实投入、长期记录、E4 和正式协议仍待验证